

Audit-Trail Final Report

Project: **vulnerable-invoice-service** · Stage 5 (aggregate) · Generated 2026-06-10 · Health Score: **0 / 100** **Grade D — high risk**

Executive summary

- **9** dependencies scanned · **13** CVEs · **1 CRITICAL / 4 HIGH** dependencies.
- **Supply-chain:** **BLOCK** — 1 typosquat + 1 untrusted HTTP repository.
- **Licenses:** 1 violation (GPL-2.0 on mysql-connector-java).
- **Remediation:** consolidated fix PR open (log4j → 2.17.1, jackson-databind → 2.13.4.2, typosquat removed).
- **Latest gate outcome:** **BLOCK** until the fix PR merges.

Health score breakdown

Factor	Deduction
Unresolved CRITICAL CVEs (4 × -15)	-60
Unresolved HIGH CVEs	-16
Supply-chain BLOCK findings (2 × -10)	-20
Outdated major-version deps	-9
Score (floored at 0)	0 / 100

Projected after the consolidated fix PR merges: removing the typosquat + the HTTP repo and bumping log4j/jackson clears the CRITICAL/HIGH CVEs and the supply-chain block → projected **~88 / 100 (Grade B)**, remaining deductions from guava (major review) and routine outdated bumps.

Top risks (ranked)

Coordinate	Risk	Band	Top CVE	Status
log4j-core / log4j-api	7.8	HIGH	CVE-2021-44228	fix in PR
jackson-databind	7.8	HIGH	CVE-2019-14379	fix in PR
com.fastxml...:jackson-databind	—	CRITICAL	typosquat	remove in PR
guava	6.0	HIGH	CVE-2023-2976	MAJOR_REVIEW

Remediation activity

Dependency	Change	CVEs cleared	Status
log4j-core / log4j-api	2.14.1 → 2.17.1	CVE-2021-44228, -45046, -45105, -44832	in fix PR
jackson-databind	2.9.8 → 2.13.4.2	8 CVEs (incl. 2 critical)	in fix PR
com.fastxml typosquat	removed	n/a (supply-chain)	in fix PR
guava	24 → 32	CVE-2023-2976	MAJOR_REVIEW issue

Gate (Stage 4) — current verdict: BLOCK

Check	Result
Unit tests	PASS
OWASP CVE (0 CRITICAL/HIGH)	FAIL
Supply-chain audit	FAIL (BLOCK)

Aggregated from `depscan-report.json` , `depscan-risk-report.json` , and the supply-chain audit. Generated by the Dependency & Supply-Chain Plugin — Stage 5.